

Acme — Vendor Onboarding Process

Effective 2024 | Procurement and Compliance

1. Eligibility requirements

Acme works with vendors that meet baseline financial, operational, and ethical standards. Prospective vendors must be a registered business entity for at least 2 years, hold all applicable industry licenses, and carry general liability insurance of at least 1 million dollars per occurrence.

Vendors providing services that handle Acme customer data must additionally hold a current SOC 2 Type II report, or equivalent independent attestation, dated within the last 12 months. Vendors providing services that touch payment card data must be PCI-DSS compliant at the appropriate merchant level.

Small and emerging vendors that do not yet meet the financial or audit requirements may apply through the Acme Emerging Vendor program, which has reduced requirements but lower spend caps and quarterly review cycles. The Emerging Vendor program is detailed in a separate addendum.

2. Application submission

Applications are submitted through the vendor portal and require company registration documents, three customer references, current insurance certificates, and the relevant compliance attestations described in section 1. Incomplete applications are returned without review.

Application review typically completes within 10 business days. Vendors are notified of decisions by email, including any conditional requirements that must be met before contracting.

3. Background and compliance checks

All vendors pass through a standard background check that includes corporate registration verification, sanctions screening (OFAC, EU consolidated list, UK HMT list), litigation history search, and a review of news and public records for the past 5 years. The screening is performed by an independent third party.

Vendors handling customer data also undergo an information security questionnaire and a remote evidence review of their security controls. The questionnaire covers identity and access management, encryption practices, incident response, and personnel security. Vendors who score below the required threshold may be offered a remediation period of up to 90 days before re-screening.

Adverse findings do not automatically disqualify a vendor. The compliance team reviews each finding and may approve the vendor with mitigating controls, additional contractual protections, or a reduced scope of engagement. Findings that involve active sanctions matches or current fraud litigation are non-negotiable disqualifiers.

4. Contract negotiation

Approved vendors receive a draft Master Services Agreement (MSA) and applicable Data Processing Addendum (DPA) for review. Standard contractual terms are non-negotiable for vendors below 250,000 dollars in projected annual spend. Larger engagements may negotiate specific terms with the involvement of Acme Legal.

Vendors who refuse standard insurance, indemnification, or data protection clauses below the negotiation threshold are not onboarded. Standard turnaround for contract execution is 15 business days from the date the draft is shared.

5. System integration

Once contracts are executed, vendors are provisioned access to the necessary Acme systems through the vendor onboarding workflow. Access is granted on a least-privilege basis: vendors only see what they need for the contracted scope of work.

Integration testing is required before the vendor is moved to production. For data-handling vendors, this includes a joint penetration test of the integration boundary and verification of audit logging. For service vendors, this includes a service-level rehearsal and runbook walkthrough.

Production go-live is approved jointly by the Acme business owner, procurement, and information security. Vendors are subject to a 60-day stabilization period during which any unresolved issues may result in scope reduction or contract suspension.

6. Ongoing compliance reviews

All vendors are reviewed annually for continued compliance. Vendors handling customer data are reviewed every 6 months. Reviews include re-submission of insurance and compliance attestations, refreshed background screening, and a sample audit of work delivered.

Failure to maintain compliance results in vendor status being placed on hold, during which no new work may be assigned. Vendors on hold for more than 90 days are off-boarded automatically.